

Penetration Test Report

Prepared for **Acme Corp** — Adversarial Simulation



ENGAGEMENT	RT-DEMO-868	WINDOW	May 15, 2026 – May 27, 2026
VERSION	1.0	ISSUED	June 1, 2026
LEAD	Admin	TEAM	Admin
CLASSIFICATION	Confidential — Restricted		

Document Control

Revision History

Version	Date	Author	Approved by	Status
1.0	June 1, 2026	Admin	—	Draft

Confidentiality Notice

This document contains confidential and proprietary information belonging to the client and the assessing firm. It is intended solely for the use of the named recipient(s). Disclosure, copying, distribution, or use of the contents of this document by any person other than the intended recipient is strictly prohibited.

The findings, recommendations, and opinions expressed in this report reflect the state of the assessed systems at the time of testing only. The assessing firm accepts no liability for the use or misuse of information contained herein.

Distribution: This report is classified *Confidential — Restricted*. Retain securely and do not transmit over unencrypted channels. Evidence and raw data are retained for 90 days and then cryptographically shredded.

Contents

0. Document Control	2
0.1. Revision History	2
0.2. Confidentiality Notice	2
1. Executive Summary	4
1.1. Findings at a Glance	4
1.2. Project Scope	4
1.3. Key Security Strengths	4
1.4. Key Areas for Improvement	4
2. Strategic Recommendations	6
2.1. Immediate Actions (0–30 Days)	6
2.2. Short-Term Improvements (30–90 Days)	6
2.3. Long-Term Security Hardening	6
3. Technical Details	7
3.1. Technical Scope	7
3.2. Testing Details	7
3.3. Engagement Timeline	7
4. Detailed Findings	9
4.1. Critical Risk Findings	10
F-003 LSASS Credential Dumping — No Credential Guard	11
4.2. High Risk Findings	12
F-001 Weak Service Account Passwords	13
F-002 Insufficient Network Segmentation	14
4.3. Medium Risk Findings	15
E-001 Initial OSINT & Target Reconnaissance	16
E-002 Spearphishing Campaign — Initial Access	17
E-003 C2 Infrastructure Established	18
E-004 Internal Reconnaissance & Domain Enumeration	19
E-005 Kerberoasting — Credential Access	20
E-006 Lateral Movement to SQL Cluster	21
E-007 Privilege Escalation via PrintSpoofer	22
E-008 Domain Dominance — DCSync & Persistence	23
E-009 Data Exfiltration — R&D Documents	24
E-010 Cleanup & Report Preparation	25
F-004 Insufficient Detection Coverage for Kerberoasting (T1558.003)	26
Appendix A — CVSS Severity Ratings	27
Appendix B — Tools and Techniques	28

Executive Summary

Executive Summary

Acme Corp — Adversarial Simulation engaged our security team to conduct a comprehensive penetration assessment of its Red Team environment between 2026-05-16 and 2026-05-28. The objective was to identify, validate, and prioritize exploitable security vulnerabilities before malicious actors could exploit them.

Risk Posture

The overall risk posture is assessed as **Medium** with a composite CVSS score of **4.9**. The assessment identified **14 findings** across the in-scope environment:

Severity	Count
Critical	1
High	2
Medium	11
Low	0
Informational	0

Key Risk Areas

The most significant findings requiring immediate remediation are:

- **Weak Service Account Passwords** (High)
- **Insufficient Network Segmentation** (High)
- **LSASS Credential Dumping — No Credential Guard** (Critical)

Recommendation Summary

The assessment team recommends that all **Critical** and **High** severity findings be remediated within **7 and 14 days** respectively, following a risk-prioritized remediation plan. Medium severity findings should be addressed within 30 days as part of the next scheduled development cycle.

Management attention is drawn to the systemic nature of certain vulnerability classes identified during this assessment. A root-cause analysis approach — rather than point-fix remediation — is strongly recommended to prevent recurrence across the application portfolio.

Findings at a Glance

All issues identified during the engagement are summarized in **Table 1**.

Critical	High	Medium	Low	Informational
1	2	11	0	0

Table 1. Total findings by severity.

Project Scope

The following assets were in scope for this engagement:

No scope defined.

Key Security Strengths

- Multi-factor authentication is enforced on all critical systems
- Regular security awareness training is conducted for all employees
- Network segmentation is properly configured between production and development environments
- Incident response procedures are documented and tested annually

Key Areas for Improvement

- Several high-severity findings require immediate remediation, particularly around patch management
- Logging and monitoring coverage should be expanded to include application-layer visibility
- Access control policies need review — multiple instances of excessive permissions were identified
- Vulnerability scanning frequency should be increased to weekly for critical assets

Strategic Recommendations

Immediate Actions (0–30 Days)

The following critical and high-severity findings require immediate attention:

- **CRITICAL F-003** — LSASS Credential Dumping — No Credential Guard: Enable Windows Credential Guard on all Windows 10/11 and Server 2019+ systems
- **HIGH F-001** — Weak Service Account Passwords: Enforce 24+ character random passwords for all service accounts
- **HIGH F-002** — Insufficient Network Segmentation: Implement VLAN ACLs restricting user-to-server traffic to authorized ports only

Short-Term Improvements (30–90 Days)

Address medium-severity findings to reduce overall attack surface:

- **MEDIUM E-001** — Initial OSINT & Target Reconnaissance
- **MEDIUM E-002** — Spearphishing Campaign — Initial Access
- **MEDIUM E-003** — C2 Infrastructure Established
- **MEDIUM E-004** — Internal Reconnaissance & Domain Enumeration
- **MEDIUM E-005** — Kerberoasting — Credential Access
- **MEDIUM E-006** — Lateral Movement to SQL Cluster
- **MEDIUM E-007** — Privilege Escalation via PrintSpoofer
- **MEDIUM E-008** — Domain Dominance — DCSync & Persistence
- **MEDIUM E-009** — Data Exfiltration — R&D Documents
- **MEDIUM E-010** — Cleanup & Report Preparation
- **MEDIUM F-004** — Insufficient Detection Coverage for Kerberoasting (T1558.003)

Long-Term Security Hardening

The following strategic initiatives are recommended to strengthen the overall security programme:

- Implement a continuous vulnerability management programme with quarterly assessments.
- Establish a formal secure development lifecycle (SDLC) with security gates at design, code review, and deployment stages.
- Deploy a security information and event management (SIEM) solution for real-time threat detection.
- Conduct annual penetration tests against all internet-facing assets and internal network segments.

Technical Details

Technical Scope

The following assets were evaluated during this engagement:

Asset / URL	Type	Notes
No scope assets defined.		

Testing Methodology

Methodology

This penetration test was conducted in accordance with industry-standard frameworks including the **Penetration Testing Execution Standard (PTES)**, **OWASP Testing Guide v4.2**, and **NIST SP 800-115**.

Testing Phases

- 1. Reconnaissance & Intelligence Gathering** Passive and active information gathering to map the attack surface, enumerate endpoints, and identify technology stack components.
- 2. Threat Modelling** Analysis of the application architecture to identify high-value targets, trust boundaries, and potential attack chains.
- 3. Vulnerability Identification** Systematic testing combining automated scanning (Burp Suite Professional, OWASP ZAP) with manual testing techniques across all OWASP Top 10 categories and application-specific business logic.
- 4. Exploitation & Validation** Manual exploitation of identified vulnerabilities to confirm impact and eliminate false positives. All exploitation was conducted safely to avoid disruption to production systems.
- 5. Post-Exploitation Analysis** Assessment of lateral movement potential and business impact of successful exploitation chains.
- 6. Reporting** Documentation of all findings with detailed reproduction steps, risk ratings, and actionable remediation guidance prioritized by business impact.

Tools & Techniques

Burp Suite Professional	– Web proxy, scanner, intruder
OWASP ZAP	– Automated scanning and fuzzing
sqlmap	– SQL injection detection and exploitation
ffuf / dirb	– Directory and endpoint enumeration
Nmap / Masscan	– Port scanning and service enumeration
Nuclei	– Template-based vulnerability scanning
Custom scripts	– Application-specific test cases

#	Activity	Primary Tooling
01	Reconnaissance	OSINT, DNS enumeration, asset discovery, Shodan
02	Threat Modelling	STRIDE analysis against service map
03	Vulnerability Analysis	Burp Suite Pro, Semgrep, Nuclei, manual testing
04	Exploitation	Controlled PoC — scoped to confirm impact only
05	Post-Exploitation	Read-only confirmation within agreed rules of engagement
06	Reporting	CVSS 3.1 scoring, CWE/OWASP mapping

Engagement Timeline

Milestone	Date / Period
Assessment Start	May 15, 2026
Assessment End	May 27, 2026
Report Issued	June 1, 2026

Rules of Engagement — No destructive testing, no customer PII handling, and no testing of out-of-scope third-party processors. Testing was conducted during agreed windows only.

Detailed Findings

All 14 identified findings are enumerated below, ordered by severity. Full technical details follow on subsequent pages.

ID	Severity	Title	Component	CVSS
F-003	CRITICAL	LSASS Credential Dumping — No Credential Guard	—	9.8
F-001	HIGH	Weak Service Account Passwords	—	8.2
F-002	HIGH	Insufficient Network Segmentation	—	7.5
E-001	MEDIUM	Initial OSINT & Target Reconnaissance	—	—
E-002	MEDIUM	Spearphishing Campaign — Initial Access	—	—
E-003	MEDIUM	C2 Infrastructure Established	—	—
E-004	MEDIUM	Internal Reconnaissance & Domain Enumeration	—	—
E-005	MEDIUM	Kerberoasting — Credential Access	—	—
E-006	MEDIUM	Lateral Movement to SQL Cluster	—	—
E-007	MEDIUM	Privilege Escalation via PrintSpoofer	—	—
E-008	MEDIUM	Domain Dominance — DCSync & Persistence	—	—
E-009	MEDIUM	Data Exfiltration — R&D Documents	—	—
E-010	MEDIUM	Cleanup & Report Preparation	—	—
F-004	MEDIUM	Insufficient Detection Coverage for Kerberoasting (T1558.003)	—	6.4

Refer to Appendix A for CVSS severity rating definitions. Each finding on the following pages includes full technical details, reproduction steps, impact analysis, and remediation guidance.

Critical Risk Findings

CRITICAL

1 finding

Avg CVSS: 9.8

Critical findings represent direct, immediate threats exploitable with low effort. These require emergency remediation.

ID	Title	CVSS	Page
F-003	LSASS Credential Dumping — No Credential Guard	9.8	11

FINDING F-003

LSASS Credential Dumping — No Credential Guard

SEVERITY	CRITICAL
CVSS V3.1	9.8
CWE	CWE-312

Description

Windows Credential Guard was not enabled on any domain-joined workstations or servers. This allowed the LSASS process memory to be dumped and cached credentials extracted, including a Domain Admin NTLM hash.

Impact

The extracted Domain Admin credentials provided full control over the Active Directory forest. With Credential Guard enabled, LSASS would run in a virtualized secure mode (VBS) preventing credential extraction even with SYSTEM privileges.

Recommendations

1. Enable Windows Credential Guard on all Windows 10/11 and Server 2019+ systems
2. Deploy LSA Protection via Group Policy
3. Implement tiered administration model (Tier 0/1/2)
4. Ensure Domain Admins do not log into non-Tier-0 systems

High Risk Findings

HIGH 2 findings

Avg CVSS: 7.8

High-severity findings pose significant risk to system integrity, confidentiality, or availability.
Remediate within 30 days.

ID	Title	CVSS	Page
F-001	Weak Service Account Passwords	8.2	13
F-002	Insufficient Network Segmentation	7.5	14

FINDING F-001

Weak Service Account Passwords

SEVERITY	HIGH
CVSS V3.1	8.2
CWE	CWE-521

Description

Multiple service accounts were found to have weak passwords that were cracked within 2 hours using hashcat with standard wordlists and corporate-specific mutations. The svc-sql account password "AcmeSQL2024!" passed complexity requirements but was easily guessable.

Impact

Compromise of service accounts provided lateral movement paths to 12 servers including the SQL cluster. A Domain Admin account was subsequently compromised from a server where it had recently authenticated.

Recommendations

1. Enforce 24+ character random passwords for all service accounts
2. Implement Managed Service Accounts (MSAs) where supported
3. Deploy a Privileged Access Management (PAM) solution
4. Conduct quarterly service account audits

FINDING F-002

Insufficient Network Segmentation

SEVERITY	HIGH
CVSS V3.1	7.5
CWE	CWE-923

Description

The user workstation VLAN (10.2.0.0/16) had unrestricted Layer 3 connectivity to the server VLAN (10.4.0.0/16). Once a foothold was established on a user workstation, the red team was able to directly scan, authenticate to, and compromise servers without encountering any firewall restrictions.

Impact

Lack of segmentation reduced the attack path from initial workstation compromise to domain dominance to a single hop. Network isolation would have forced additional exploitation steps, increasing the chance of detection.

Recommendations

1. Implement VLAN ACLs restricting user-to-server traffic to authorized ports only
2. Deploy jump hosts with MFA for all server administrative access
3. Micro-segment the server VLAN by application tier

Medium Risk Findings

MEDIUM

11 findings

Avg CVSS: 6.4

Medium-severity findings require non-trivial preconditions but materially weaken security posture. Remediate within 90 days.

ID	Title	CVSS	Page
E-001	Initial OSINT & Target Reconnaissance	—	16
E-002	Spearphishing Campaign — Initial Access	—	17
E-003	C2 Infrastructure Established	—	18
E-004	Internal Reconnaissance & Domain Enumeration	—	19
E-005	Kerberoasting — Credential Access	—	20
E-006	Lateral Movement to SQL Cluster	—	21
E-007	Privilege Escalation via PrintSpoofer	—	22
E-008	Domain Dominance — DCSync & Persistence	—	23
E-009	Data Exfiltration — R&D Documents	—	24
E-010	Cleanup & Report Preparation	—	25
F-004	Insufficient Detection Coverage for Kerberoasting (T1558.003)	6.4	26

FINDING E-001

Initial OSINT & Target Reconnaissance

SEVERITY

MEDIUM

Description

Conducted passive reconnaissance against Acme Corp's external perimeter. Identified employee email addresses via LinkedIn, corporate structure via the company website, and technology stack from job postings. Discovered the company uses Office 365 with Azure AD Connect for hybrid identity.

Impact

Reconnaissance revealed the attack surface: O365/Azure hybrid environment, VPN gateway (Pulse Secure), and several internet-facing web applications. The IT team's LinkedIn profiles revealed they used PowerShell extensively, suggesting a phishing lure involving a "PowerShell troubleshooting guide" would be effective.

FINDING E-002

Spearphishing Campaign — Initial Access

SEVERITY

MEDIUM

Description

Crafted a targeted spearphishing email impersonating the internal IT helpdesk, sent to 12 employees in the engineering and finance departments. The email contained a "new VPN configuration guide" with a malicious macro-enabled Excel attachment. Two employees opened the attachment and enabled macros within the first 4 hours.

Impact

Gained initial foothold on two workstations: ENG-WS-047 (engineer, local admin rights) and FIN-WS-012 (finance analyst, standard user). Both beacons called back to the C2 infrastructure within minutes of macro execution.

FINDING E-003

C2 Infrastructure Established

SEVERITY

MEDIUM

Description

Deployed Cobalt Strike HTTPS beacon on both compromised hosts. Configured beacon to use jitter (30%), sleep intervals (45s during work hours, 300s outside), and DNS fallback channel. C2 domain (update-cdn.acme-corp[.]com) was registered 14 days prior and passed the target's web proxy categorization.

FINDING E-004

Internal Reconnaissance & Domain Enumeration

SEVERITY

MEDIUM

Description

Executed SharpHound to enumerate Active Directory topology. Discovered 2,400+ users, 1,800+ computers, 84 groups. Identified several high-value targets: Domain Admins group (8 members), SQL service accounts with weak SPNs, and a misconfigured Certificate Services server. Mapped trust relationships — no external trusts, single forest.

Impact

The AD topology revealed a flat structure with no tiered administration model. Service accounts had excessive privileges. Several Domain Admin accounts were used on regular workstations — a critical hygiene gap that the red team exploited later.

FINDING E-005

Kerberoasting — Credential Access

SEVERITY

MEDIUM

Description

Used Rubeus to request TGS tickets for all accounts with SPNs set. Extracted 14 service account hashes. Cracked 6 of them offline within 2 hours using hashcat with the rockyou.txt wordlist and Acme-specific mutations. The svc-sql account had a password of "AcmeSQL2024!" — weak but not in standard dictionaries.

Impact

The svc-sql account was a member of the "Server Operators" group on the SQL cluster and had local administrator rights on 12 servers. This provided a stepping stone to the server VLAN.

FINDING E-006

Lateral Movement to SQL Cluster

SEVERITY

MEDIUM

Description

Used the compromised svc-sql credentials to authenticate to SQL-DB-01 via SMB. Deployed a Cobalt Strike SMB beacon for internal pivoting. Enumerated the server's running processes and discovered a scheduled task running as DOMAIN\spl-agent, a domain account with SelpersonatePrivilege.

FINDING E-007

Privilege Escalation via PrintSpoofer

SEVERITY

MEDIUM

Description

Exploited SelpersonatePrivilege on the sql-agent account using PrintSpoofer to escalate to NT AUTHORITY\SYSTEM on SQL-DB-01. From SYSTEM, dumped LSASS memory and extracted the credentials of a logged-on Domain Admin (CORP\jwilson) who had recently RDP'd into the server to troubleshoot a performance issue.

Impact

Obtained Domain Administrator credentials within 6 days of initial access. The Domain Admin had logged into the SQL server 3 hours before the credential dump — timing was fortuitous but the technique would have worked with any high-privilege account.

FINDING E-008

Domain Dominance — DCSync & Persistence

SEVERITY

MEDIUM

Description

Using the Domain Admin credentials, executed DCSync via Mimikatz to extract the NTLM hash of the KRBTGT account. Created a Golden Ticket for persistent domain access. Also extracted password hashes for all Domain Admins and 40+ service accounts from NTDS.dit. Created a backdoor domain account (CORP\redteam_svc) added to Domain Admins group.

Impact

Achieved full domain compromise — the red team could now authenticate as any user, access any system, and persist indefinitely. The backdoor account was camouflaged as a legitimate service account with a description matching the corporate naming convention.

FINDING E-009

Data Exfiltration — R&D Documents

SEVERITY

MEDIUM

Description

Identified the R&D file share (\\files\R&D) via domain enumeration. Accessed it using the Domain Admin session. Located and exfiltrated two key documents: the 2027 product roadmap and a confidential M&A target analysis. Data was compressed, encrypted, and exfiltrated in 2MB chunks over the existing HTTPS C2 channel to blend with normal web traffic.

Impact

Successfully exfiltrated 18MB of sensitive R&D documents. The exfiltration generated no alerts — traffic patterns matched the organization's normal O365 telemetry. The SOC had no visibility into internal file share access auditing.

FINDING E-010

Cleanup & Report Preparation

SEVERITY

MEDIUM

Description

Removed persistence mechanisms (scheduled tasks, service accounts, WMI subscriptions). Cleared Windows Event Logs on compromised hosts where possible. Left the backdoor account in place per the rules of engagement (the blue team will use it for detection engineering practice). Prepared the campaign timeline and observations for the final report.

FINDING F-004

Insufficient Detection Coverage for Kerberoasting (T1558.003)

SEVERITY	MEDIUM
CVSS V3.1	6.4
CWE	CWE-770

Description

The SIEM was not configured to alert on Event ID 4769 with Ticket Encryption Type 0x17 (RC4-HMAC). The red team successfully performed Kerberoasting, extracting 14 service ticket hashes, and cracked 6 offline without generating any security alerts.

Impact

Kerberoasting is one of the most commonly used credential access techniques. The lack of alerting meant the red team operated undetected during a critical phase of the kill chain. The SOC had all necessary telemetry but lacked the detection rules to act on it.

Recommendations

1. Deploy Sigma rule for Kerberoasting detection (Event ID 4769, Encryption Type 0x17)
2. Monitor for unusual volumes of TGS requests from single hosts
3. Audit all accounts with SPNs and remove unnecessary service principals

Appendix A — CVSS Severity Ratings

Severity is assigned per finding using the *Common Vulnerability Scoring System v3.1*. Each finding records both the numerical score and vector string, allowing re-derivation against custom environmental context.

Severity	CVSS Range	Definition
CRITICAL	9.0 – 10.0	Direct, immediate threat. Exploitable by an unauthenticated attacker with low effort. Remediate immediately.
HIGH	7.0 – 8.9	Significant threat to sensitive systems or data, or a meaningful component of an attack chain. Remediate within 30 days.
MEDIUM	4.0 – 6.9	Threat requiring non-trivial preconditions but materially weakening posture. Remediate within 90 days.
LOW	0.1 – 3.9	Minor exposure with limited impact in isolation. Address as part of regular hygiene within 180 days.
INFORMATIONAL	0.0	Observation worth noting for hardening or hygiene. No immediate risk.

Note — CVSS scores reflect the *base score* only. Temporal and environmental modifiers are noted where relevant. Clients are encouraged to apply their own environmental vector to adjust scores to their specific context.

Appendix B — Tools and Techniques

The following tools and techniques were employed during the assessment. All tools were used in accordance with the agreed rules of engagement.

Tool / Technique	Category	Purpose
Burp Suite Professional	Web Proxy	HTTP interception, active scanning, session analysis
Nuclei	Scanner	Template-based vulnerability detection across web surfaces
Nmap / Naabu	Network Scanner	Port discovery, service version detection, OS fingerprinting
ffuf / Feroxbuster	Fuzzing	Directory enumeration, parameter fuzzing, wordlist attacks
Semgrep	SAST	Static analysis for common vulnerability patterns in source code
SQLMap	Exploitation	Automated SQL injection detection and exploitation
Amass / Subfinder	OSINT / Recon	Subdomain enumeration and asset discovery
JWT Tool	Token Analysis	JWT signature algorithm confusion and secret brute-forcing
Hashcat	Password Cracking	Offline hash cracking with GPU acceleration
Manual Testing	Methodology	Logic flaws, business process abuse, authentication bypass

Appendix C — Glossary

Key terms used throughout this report are defined below.

Term	Definition
Attack Surface	The set of all points at which an attacker can enter or extract data from a system.
Authentication Bypass	A vulnerability allowing access to protected resources without valid credentials.
CVSS	Common Vulnerability Scoring System — a standardised framework for rating vulnerability severity.
CWE	Common Weakness Enumeration — a community-developed list of software and hardware weakness types.
IDOR	Insecure Direct Object Reference — direct access to objects (records, files) using user-controlled input.
Lateral Movement	Techniques used by attackers to progressively move through a network after initial compromise.
OWASP	Open Worldwide Application Security Project — provides freely available security guidance and tools.
Penetration Test	Authorised simulated cyberattack against a computer system to evaluate security weaknesses.
PoC	Proof of Concept — a demonstration that a vulnerability exists and can be exploited.
PTES	Penetration Testing Execution Standard — a common methodology framework for penetration tests.
Remediation	The process of fixing or mitigating a discovered security vulnerability.
SQL Injection	Insertion of malicious SQL code into a query via user-supplied input fields.
STRIDE	A threat modelling framework covering Spoofing, Tampering, Repudiation, Info Disclosure, DoS, Elevation.
XSS	Cross-Site Scripting — injection of malicious scripts into web pages viewed by other users.